AMRITA VISHWA VIDYAPEETHAM MYSURU CAMPUS

DEEMED TO BE UNIVERSITY UNDER SECTION 3 OF UGC ACT 1956

School of Computing

COURSE PLAN

Department	MCA
Course Title	WEB APPLICATION SECURITY
Course Code	24CA535
Programme and Section	MCA
Academic Year	2025-26
Semester	III
LTP/ hours per week- Credit	L: 03, T: 00 and P: 01, **4 Credits**
Course Instructor Details	Mr. Santhosh Kumar B.J bj_santoshkumar@my.amrita.edu

Programme Outcomes:

1. **Computational Knowledge:** Apply knowledge of computing fundamentals, computing specialization, mathematics, and domain knowledge appropriate for the computing specialization to the abstraction and conceptualization of computing models from defined problems and requirements.
2. **Problem Analysis:** Identity, formulate, research literature, and solve complex computing problems reaching substantiated conclusions using fundamental principles of mathematics, computing sciences, and relevant domain disciplines.
3. **Design /Development of Solutions:** Design and evaluate solutions for complex computing problems, and design and evaluate systems, components, or processes that meet specified needs with appropriate consideration for public health and safety, cultural, societal, and environmental considerations.

4. **Conduct Investigations of Complex Computing Problems:** Use research-based knowledge and research methods, including design of experiments, analysis, and interpretation of data, and synthesis of the information to provide valid conclusions
5. **Modern Tool Usage:** Create, select, adapt and apply appropriate techniques, resources, and modern computing tools to complex computing activities, with an understanding of the limitations.
6. **Professional Ethics:** Understand and commit to professional ethics and cyber regulations, responsibilities, and norms of professional computing practice.
7. **Life-long Learning:** Recognize the need and ability to engage in independent learning for continual development as a computing professional.
8. **Project management and finance:** Demonstrate knowledge and understanding of the computing and management principles and apply these to one's work, as a member and leader in a team, to manage projects and in multidisciplinary environments.
9. **Communication Efficacy:** Communicate effectively with the computing community, and with society at large, about complex computing activities by being able to comprehend and write effective reports, design documentation, make effective presentations, and give and understand clear instructions.
10. **Societal and Environmental Concern:** Understand and assess societal, environmental, health, safety, legal, and cultural issues within local and global contexts and the consequential responsibilities relevant to professional computing practice.
11. **Individual and Teamwork:** Function effectively as an individual and as a member or leader in diverse teams and multidisciplinary environments.
12. **Innovation and Entrepreneurship**: Identify a timely opportunity and use innovation to pursue that opportunity to create value and wealth for the betterment of the individual and society at large.

Course Outcomes (COs): COs Description

- Understand the security requirements in web applications.
- Understand the injection attack against web applications
- Ability to implement secure coding practices.
- Trained in responsible vulnerability disclosure.

School of Computing

	PO1	PO2	PO3	PO4	PO5	PO6	PO7	PO8	PO9	PO10	PO11	PO12
CO 1	2	0	0	0	3	0	0	0	0	0	0	0
CO 2	3	1	0	0	2	0	0	0	0	0	0	0
CO 3	3	0	2	0	1	0	0	0	0	0	0	0
CO 4	1	0	0	0	1	0	0	0	0	0	0	0

Course Objectives

- This course provides basic knowledge and skills in the fundamental theories and practices of cyber security.
- It provides an overview of the field of security and assurance emphasizing the need to protect Information being transmitted electronically

Prerequisites:

Basic knowledge of computer networks.

week	Lecture No(s)	Topics	Key-words	Teaching Aids	CO mapping	Text book
1	1	Introduction	Introduction to Web application security	Blackboard	CO1	Text Book 1, chapter 1
	2	Overview of web architecture	web architecture: client-server	Blackboard	CO1	Text Book Ichapter 1
	3	Protocols, Client-server architecture,	Client,server,protocols	Blackboard	CO1	Text Book chapter 1

School of Computing

2	4	P2P architecture,DNS	Peer to Peer,DNS protocol	PowerPoint	CO2	Text Book Ichapter 2
	5	Understanding the browser: Same origin policy, Cookies, Cache, authentication	Browser, Policy, Cookies, Cache, authentication	PowerPoint	CO2	Text Book I chapter 2
	6	Website development basics	Client side and server code coding	PowerPoint	CO2	Text Book I chapter 2
3	7	understanding server-side languages like HTML, PHP	PHP	PowerPoint	CO2	Text Book I chapter 2
	8	Database languages such as SQL	SQL	PowerPoint	CO2	Text Book I chapter 2
	9	Understanding the frontend, backend	frontend is HTML, CSS, and backend: JavaScript. PHP	Blackboard	CO1	Text Book I chapter 1
4	10	Database paradigm of web application development.	Database paradigm of web application development	Blackboard	CO3	Text Book I chapter 5
	11	Injection attacks: SQL injection	SQL injection	Blackboard	CO3	Text Book I chapter 2
	12	Injection attacks :OS command injection	OS command injection	Demo	CO3	Text Book I chapter 5
5	13	File upload vulnerability: : LFI and RFI how to properly secure a file inclusion vulnerability.	Local File Inclusion (LFI) and Remote File Inclusion (RFI)	Demo	CO3	Text Book I chapter 4
	14		Remote File Inclusion (RFI)	Blackboard	CO3	
	15		Preventing Local File Inclusion vulnerabilities · ID assignation	Blackboard	CO3	
	19	Request forgery vulnerability: client-	Request forgery vulnerability: client-server	Blackboard	CO3	

6	20	server SSRF,CSRF	Server-side request forgery (SSRF)	Demo	CO3	Text Book I chapter 4
	21	Server-side request forgery, Client-side request forgery	Client-side request forgery(CSRF)	Blackboard	CO3	Text Book I chapter 6
			Midterm exam			
7	22	Cross-site scripting attacks: Reflected XSS,	XSS(CSS)	Demo	CO3	Ref Book II chapter 8
	23		Reflected XSS	Blackboard	CO3	
	24	Stored XSS, how to properly secure against XSS attacks.	Stored XSS	Demo	CO3	
8	25	DOS & DDOS attacks, DDOS	DOS attacks	Blackboard	CO3	Ref Book II chapter 6
	26		DDOS attacks	Blackboard	CO3	
	27	Phishing attacks.	Phishing attacks	Blackboard	CO3	
9	28	Automating vulnerabilities: SQLmap, Burp Suite	SQLmap, Burp Suite	Blackboard	CO3	Ref Book II Chapter7
	29	Automating vulnerabilities: Burp Suite	Burp Suite	Blackboard	CO4	
	30	OWASP Top 10: Broken Authentication,	Broken Authentication	Blackboard	CO4	
Technical session on Web vulnerability tool SQL Map/Burp Suite by Mr Indrajeeth						
10	31	OWASP Top 10:		Blackboard	CO4	

	32	Sensitive Data Exposure	Sensitive Data Exposure	Demo	CO4	
	33	XML External Entities	XML External Entities	Blackboard	CO4	
11	34	Broken Access Control,	Broken Access Control	Demo	CO4	
	35	Security Misconfiguration	Security Misconfiguration	Blackboard	CO4	Ref Book II Chapter7
	36	Insecure Deserialization,	Insecure Deserialization	Blackboard	CO4	Ref Book II Chapter7
12	37	Using Components with Known Vulnerabilities	Using Components with Known Vulnerabilities	Blackboard	CO4	Ref Book II Chapter8
	38	Insufficient Logging & Monitoring.	Insufficient Logging & Monitoring	Demo	CO4	Ref Book II Chapter8
	39	Responsible vulnerability disclosure: CVE's,	Responsible vulnerability disclosure: CVE's,	Blackboard	CO5	Ref Book II Chapter9
13	40	CVEmitre, Exploit-db, SearchSploit, bug bounty	CVEmitre, Exploit-db, SearchSploit, bug bounty	Blackboard	CO5	Ref Book II Chapter10
	41	Secure coding practices: blacklisting	blacklisting	Blackboard	CO5	Ref Book II Chapter10
	42	Secure coding practices: whitelisting	whitelisting	Blackboard	CO5	Ref Book II Chapter13
14	43	user input validation	user input validation	Blackboard	CO5	Ref Book II Chapter13
	44	Automated testing	Automated testing	Blackboard	CO5	Ref Book II Chapter13
	45	sanitizing HTML	sanitizing HTML	Blackboard	CO5	Ref Book II Chapter13
End Semester						

AMRITA VISHWA VIDYAPEETHAM MYSURU CAMPUS
DEEMED TO BE UNIVERSITY UNDER SECTION 3 OF UGC ACT 1956

School of Computing

Textbooks / References:

1. Peter Yaworski, “Real-World Bug Hunting: A Field Guide to Web Hacking”
2. Michal Zalewski, “The Tangled Web: A Guide to Securing Modern Web Applications”
3. Dafydd Stuttard and Marcus Pinto, “The Web Application Hacker's Handbook” Second edition, 2011
4. OWASP, “Web Security Testing Guide”, Fourth edition

Unit wise Evaluation Pattern

Slno	Component Name	Weightage	CO Mapping
1	Class Test 1	05 Marks	CO1
2	Midterm Exam	20	CO1,CO2
3	Lab test1	15	CO1,CO2
4	Lab test2	15	CO1,CO2,CO3,CO4
5	Observation + Record	05	CO1,CO2,CO3,CO4,CO5
6	Assignment(Certificate)	05	CO1,CO2,CO3,CO4,CO5
7	Individual Project	05	CO1,CO2,CO3,CO4,CO5

Name and Signatures:

1. Course Teacher : Mr. Santosh Kumar B.J
2. Class Representatives : Mr. Adithya Vinod - My.AC.P2MCA25102
3. Class Advisor : Dr. Pushpa B.R
4. Program Coordinator : Dr Bipin Nair B.J 20/8/26 corr. By
5. Chairperson : Dr Sudarshan Rudra

20-Aug-26.